

Contents

NationalBank Reserve — Red Team Capstone	1
Checkpoint 2: Infrastructure Assessment	1
1. Executive Summary	1
2. Methodology	1
3. Network Services Discovered	2
4. Findings & CVSS v3.1	2
5. Detailed Findings	2
6. Remediation Roadmap	4
7. Appendix — Evidence Files	4
8. Conclusion	4

NationalBank Reserve — Red Team Capstone

Checkpoint 2: Infrastructure Assessment

Analyst: Mustafa Musa Ahmed **Date:** 2026 **Classification:** CONFIDENTIAL — Authorized Lab Environment **Target:** DVWA v1.10 on Docker (Apache 2.4.25)

1. Executive Summary

An infrastructure assessment was conducted on the authorized lab environment (DVWA v1.10 running on Docker, Apache 2.4.25). The assessment identified 6 vulnerabilities, including 1 Critical and 2 High severity issues.

Overall Risk Rating: HIGH

Key Findings: - 1 CRITICAL: Database credentials exposed via .bak file (CVSS 9.8) - 2 HIGH: Directory indexing enabled + Apache 2.4.25 outdated - 3 MEDIUM/LOW: Missing security headers, PHPSESSID without HttpOnly, Admin login exposed

Business Impact: If this were a production system, an attacker could extract database credentials and gain full access to the backend database, leading to complete data compromise.

2. Methodology

Tool	Purpose
Nmap 7.98	Port scanning, service detection, OS fingerprinting
Nikto 2.6.0	Web server vulnerability scanning
Manual Verification	Confirming findings in browser + curl
CVSS v3.1	Severity scoring

Commands Used:

```
nmap -sV -sC -A -p 80 localhost -oN 01-scans/01-nmap-service-scan.txt -oX 01-scans/01-nmap-service-scan.xml nikto -h http://localhost -o 01-scans/02-nikto-scan.html -Format htm curl http://localhost/config/config.inc.php.bak -o 02-evidence/config.inc.php.bak.raw
```

3. Network Services Discovered

Port	Service	Version	Risk
80/tcp	HTTP	Apache httpd 2.4.25 (Debian)	HIGH
22/tcp	SSH	Closed	-
3306/tcp	MySQL	Closed (internally)	-
8080/tcp	HTTP-Proxy	Closed	-

Total Open Ports: 1 **Operating System:** Linux 5.0 - 6.2 **Evidence:** 01-scans/01-nmap-service-scan.txt

4. Findings & CVSS v3.1

ID	Vulnerability	CVSS	Severity
F-01	Database Credentials Exposed via .bak File	9.8	CRITICAL
F-02	Directory Indexing Enabled on /config/	7.5	HIGH
F-03	Apache 2.4.25 Outdated	7.5	HIGH
F-04	PHPSESSID Cookie Without HttpOnly Flag	5.3	MEDIUM
F-05	Missing Security Headers	5.3	MEDIUM
F-06	Admin Login Page Publicly Exposed	3.1	LOW

Total Findings: 6 **Critical:** 1 | **High:** 2 | **Medium:** 2 | **Low:** 1

5. Detailed Findings

F-01: Database Credentials Exposed via .bak File (CRITICAL)

CVSS: 9.8 **Vector:** CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H **CWE:** CWE-548

Description: The /config/ directory is publicly accessible with directory indexing enabled. A backup file config.inc.php.bak was found, containing database credentials in plaintext.

Evidence: \$_DVWA['db_server'] = '127.0.0.1'; \$_DVWA['db_database'] = 'dvwa'; \$_DVWA['db_user'] = 'app'; \$_DVWA['db_password'] = '*****';

Business Impact: An attacker can use these credentials to access the database directly and compromise the entire application.

Remediation: - Remove .bak and .dist files from production - Disable directory indexing (Options -Indexes) - Move config files outside webroot - Rotate all exposed credentials immediately

F-02: Directory Indexing Enabled on /config/ (HIGH)

CVSS: 7.5 **Vector:** CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:N/A:N

Description: The /config/ directory lists all files publicly, exposing sensitive configuration files.

Evidence: Index of /config shows: - config.inc.php - config.inc.php.bak - config.inc.php.dist

Remediation: - Disable directory indexing in Apache: Options -Indexes - Restrict access via .htaccess

F-03: Apache 2.4.25 Outdated (HIGH)

CVSS: 7.5

Description: Apache 2.4.25 (released 2016) is outdated. Current version is 2.4.66. Known CVEs include CVE-2017-15715 and CVE-2019-0211.

Evidence: Nmap and Nikto both reported: Apache/2.4.25 appears to be outdated.

Remediation: Upgrade to Apache 2.4.66 or later.

F-04: PHPSESSID Cookie Without HttpOnly Flag (MEDIUM)

CVSS: 5.3

Description: Session cookie can be stolen via XSS attacks.

Evidence: Nmap and Nikto both reported: PHPSESSID created without the httponly flag.

Remediation: Set HttpOnly and Secure flags on all session cookies.

F-05: Missing Security Headers (MEDIUM)

CVSS: 5.3

Missing Headers: - Content-Security-Policy (CSP) - Strict-Transport-Security (HSTS) - X-Content-Type-Options - Referrer-Policy - Permissions-Policy

Remediation: Add all headers in Apache config.

F-06: Admin Login Page Exposed (LOW)

CVSS: 3.1

Description: /login.php is publicly accessible.

Remediation: Add rate limiting, MFA, and CAPTCHA.

6. Remediation Roadmap

Priority	Action	Deadline
P1 - Critical	Remove .bak files + rotate credentials	24 hours
P1 - Critical	Disable directory indexing	24 hours
P2 - High	Upgrade Apache to 2.4.66+	1 week
P3 - Medium	Add HttpOnly/Secure flags to cookies	2 weeks
P3 - Medium	Add all missing security headers	2 weeks
P4 - Low	Harden admin login page	1 month

7. Appendix — Evidence Files

File	Description
01-scans/01-nmap-service-scan.txt	Nmap text output
01-scans/01-nmap-service-scan.xml	Nmap XML output
01-scans/02-nikto-scan.html	Nikto HTML report
01-scans/02-nikto-scan.txt	Nikto text output
02-evidence/config.inc.php.bak.raw	Original exposed file
02-evidence/config.inc.php.bak.REDACTED	Redacted version
02-evidence/credentials-redacted.txt	Extracted credentials

8. Conclusion

The infrastructure assessment revealed 6 vulnerabilities, including 1 CRITICAL issue (exposed database credentials) and 2 HIGH issues (directory indexing and outdated Apache). Immediate remediation is required.

This assessment provides the foundation for Checkpoint 3: Web + API Assessment.

Signed: Mustafa Musa Ahmed **Date:** 2026